

MODULE 32 · DOMAIN 6 - SECURITY FOUNDATIONS AND GOVERNANCE

AWS Organizations and the control hierarchy

Domain 6 opens here – and with declarative policies, which appear zero times in your question bank.

DOMAIN 6 of 6 EXAM WEIGHT 14% MODULE 32 of 39

An SCP denies **actions you named**. A declarative policy declares **a configuration** – and survives the actions AWS invents next year.

The policy types

POLICY	WHAT IT DOES
Service control policy	Caps what principals in your org may do
Resource control policy	Caps what may be done to your resources, by anyone
Declarative policy	Declares a service configuration that persists through new features
Tag policy	Standardises tag keys and values; reports non-compliance
Backup policy	Enforces backup plans centrally, as in module 29
AI services opt-out policy	Opts accounts out of AI service data use for improvement

ON THE EXAM

Only the first three restrict access. Tag, backup and AI opt-out policies configure behaviour rather than authorisation.

Declarative policies

- ◆ You **declare the desired configuration** for a service, enforced at the service level – not by denying named APIs.
- ◆ **Set once and forget.** Maintained when the service adds features or APIs, and when new accounts appear.
- ◆ Launch coverage: **EC2, VPC, EBS** – blocking public VPC access, disallowing public AMI sharing, enforcing VPC encryption in transit.
- ◆ **Account status reports** show the current configuration before you enforce.
- ◆ You can set a **custom error message** pointing users at internal guidance.

ON THE EXAM

Note the overlap: allowed AMIs and IMDS from module 16, VPC encryption from module 30.

SCP, or declarative policy?

SERVICE CONTROL POLICY

Denies named actions

- Any service, any action you can name
- Conditions, wildcards, full policy language
- Silently outgrown by new APIs
- The general-purpose ceiling

DECLARATIVE POLICY

Declares a configuration

- Only supported services and attributes
- Survives new features and APIs
- Account status reports before enforcing
- Narrow, and durable within its scope

THE TIEBREAKER

Use both. The SCP is the broad ceiling; the declarative policy is the setting you never want to drift, whatever AWS ships next.

Tag, backup and AI opt-out policies

- ◆ **Tag policies** define permitted keys and values and report non-compliance.
- ◆ **A tag policy cannot require that a tag exists** – it standardises values when one is applied.
- ◆ So pair a **tag policy** for values with an **SCP using a Null condition** for presence.
- ◆ **Backup policies** push AWS Backup plans org-wide, as in module 29.
- ◆ **AI services opt-out policies** opt accounts out of content being used for service improvement.

ON THE EXAM

Neither alone gives you 'tagged, and tagged correctly'.

AWS Control Tower

- ◆ Sets up a **landing zone** – log archive account, audit account, Identity Center configured.
- ◆ **Account Factory** is a configurable account template, so new accounts arrive pre-configured.
- ◆ **Controls** are plain-language rules applied to an **OU**, affecting every account inside.
- ◆ The **AWS Control Catalog** is the shared library, used by Security Hub CSPM and Audit Manager too.
- ◆ It does not replace Organizations. It sits on top and configures it.

ON THE EXAM

'Guardrail' is the older name for a control. It means the same thing.

Three kinds of control

CONTROL	IMPLEMENTED WITH	ACTS
Preventive	SCPs, RCPs and declarative policies	Blocks the action outright
Detective	AWS Config rules	Reports non-compliance after the fact
Proactive	CloudFormation hooks	Blocks provisioning before the resource exists

ON THE EXAM

Proactive controls only apply to resources provisioned by CloudFormation. Create the same resource by CLI and they do not see it.

Guidance, and the management account exception

- ◆ Guidance is **mandatory, strongly recommended**, or **elective**. Mandatory ones are always on.
- ◆ **Detective controls only apply in Control Tower-supported Regions**. Elsewhere, nothing is evaluated.
- ◆ **SCPs have no effect in the management account**. Root and IAM admins there can do anything an SCP denies.
- ◆ That is deliberate – it stops an SCP error locking you out of your own management account.
- ◆ So **run no workloads in the management account**. Nothing you write constrains them.

ON THE EXAM

The module 19 rule, with its reason attached.

A company enforces 'no public AMI sharing and no public EBS snapshots' with an SCP denying the specific API actions. Twice in two years, AWS has shipped a new mechanism for sharing images, and each time the SCP silently stopped covering it until someone noticed. The security team wants the configuration itself enforced, so that new features arrive already governed.

What should the company use?

- ☐ A A declarative policy for EC2 and EBS, enforcing the configuration at the service level
- ☐ B An SCP using NotAction, so everything except the permitted actions is denied
- ☐ C A Config rule with automatic remediation for public AMIs and snapshots
- ☐ D An RCP denying public sharing of AMIs and snapshots organisation-wide

◆ PAUSE AND DECIDE

What should the company use?

- A

 A declarative policy for EC2 and EBS
Correct. Declarative policies enforce a configuration at the service level and are maintained when the service adds features or APIs – which is the stated requirement.
- B

 An SCP using NotAction
Would cover new actions, and denies everything else in EC2 too – an enormous blast radius to solve a narrow problem, and unmaintainable in practice.
- C

 Config rule with remediation
Detective and corrective. There is a window during which the AMI is public, which is exactly the window that matters.
- D

 An RCP denying public sharing
RCPs cap what may be done to your resources by any principal – still action-based, so it inherits the same problem of being outgrown by new APIs.

THE SIGNAL

'Each time AWS shipped a new mechanism, the policy stopped covering it' is the declarative policy pitch, written as a symptom.

A financial services firm deploys all infrastructure through CloudFormation in a Control Tower environment. A recent incident involved an S3 bucket created with no encryption, which a detective control flagged forty minutes after it was created and after data had been written to it.

The requirement is that a non-compliant resource is never created at all, without adding a manual approval step to the pipeline.

What should the firm enable?

- ☐ A A detective control with an EventBridge rule triggering automatic remediation
- ☐ B An SCP denying s3:CreateBucket unless encryption is specified
- ☐ C A proactive control, implemented as a CloudFormation hook
- ☐ D A Config conformance pack applied to every account in the OU

◆ PAUSE AND DECIDE

What should the firm enable?

- A

Detective control plus automatic remediation
Faster than forty minutes and still after creation. The requirement says never created, and remediation always leaves a window.
- B

SCP denying CreateBucket without encryption
Genuinely preventive and worth having. It also blocks every creation path, which is broader than asked - and since 2023 S3 encrypts every bucket by default anyway.
- C

A proactive control via CloudFormation hook
Correct. Proactive controls scan resources before provisioning, so non-compliant resources are never created - and the firm deploys everything through CloudFormation.
- D

A Config conformance pack
Config rules are detective by definition. A conformance pack is a bundle of them, so it reports rather than prevents.

THE SIGNAL

'All infrastructure through CloudFormation' is the enabling detail. Proactive controls only see what CloudFormation provisions.

A company applies an SCP at the organisation root denying ec2:RunInstances outside two approved Regions. An audit finds EC2 instances running in four other Regions – all of them in the management account, where a legacy monitoring workload lives.

The security team confirms the SCP is attached at the root and is syntactically correct.

What is happening, and what should the team do?

- ☐ A SCPs take up to 24 hours to apply at the root; wait and re-audit
- ☐ B The SCP must also be attached to each OU individually to take effect
- ☐ C The management account has an SCP exemption for Region restrictions only
- ☐ D SCPs never affect the management account; migrate the workload to a member account

◆ PAUSE AND DECIDE

What is happening, and what should the team do?

A Wait 24 hours

SCP changes apply quickly, and the instances have been running long enough for an audit to find them. Delay does not explain a consistent exemption.

C An exemption for Region restrictions only

Half a real fact. The management account is exempt from SCPs entirely, not from one category of them.

B Attach to each OU individually

A root-attached SCP applies to every OU and account beneath it. Attaching per OU is redundant, and would not reach the management account either.

D SCPs never affect the management account; migrate the workload

Correct. AWS documents this – the exemption stops an SCP error locking the organisation out of its own management account. So workloads do not belong there.

THE SIGNAL

Every non-compliant instance is in the management account. That is not a coincidence, it is the whole answer.

A company applies a tag policy requiring a CostCentre tag with values from an approved list. Three months later, finance reports that 30% of resources still have no CostCentre tag at all. The tag policy shows no non-compliance for those resources.

Resources that do carry a CostCentre tag all have approved values.

Why, and what should the company add?

- ☐ A The tag policy is not enforced; switch it from report-only to enforcement
- ☐ B Tag policies standardise values but cannot require a tag; add an SCP denying creation when the tag is Null
- ☐ C The untagged resources are in Regions the tag policy does not cover; extend its Region scope
- ☐ D Tag policies evaluate only at creation; re-apply the policy to evaluate existing resources

◆ PAUSE AND DECIDE

Why, and what should the company add?

A Switch to enforcement mode

*Enforcement stops a non-compliant *value* being applied on supported resource types. A resource with no tag is applying no value, so there is nothing to enforce against.*

C Regions not covered

Would produce no findings for those resources - and finance can see them, so they are within scope of reporting. The gap is what a tag policy evaluates.

B Tag policies cannot require a tag; add an SCP with a Null condition

Correct. The tag policy governs values; the SCP requires presence. Neither alone gives you 'tagged, and tagged correctly'.

D Re-apply to evaluate existing resources

Tag policies do report on existing resources. The absence of findings is the clue: an untagged resource is not non-compliant, it is invisible to the policy.

THE SIGNAL

'The tag policy shows no non-compliance for those resources' is the tell. Silence means the policy has nothing to evaluate.

Six things to carry forward

- ◆ An SCP denies named actions and is outgrown by new APIs. A declarative policy is not.
- ◆ Preventive: SCPs, RCPs, declarative. Detective: Config rules. Proactive: CloudFormation hooks.
- ◆ Proactive controls only see what CloudFormation provisions.
- ◆ SCPs have no effect in the management account. Run no workloads there.
- ◆ Detective controls only cover supported Regions. Silence is not compliance.
- ◆ A tag policy cannot require a tag. Pair it with an SCP and a Null condition.

ON THE EXAM

Next: compliance and audit – Config, Audit Manager, Security Hub CSPM and Artifact.